

Risk Analysis

Threat No.	Brief Description	Likelihood	Impact	Risk	Do you agree with the Risk Level Rating?
1	An authenticated user performs high-risk functions such as setting the temperature	Medium	High	Medium	Yes
2	Untrusted executables replace the original programs	Minimal	Critical	Low	Yes
3	The heater is covered, uncovered, unplugged, or not placed in its indented position	Low	Medium	Low	Yes
4	Interception and modification of temperature data over the network	Low	High	Low	Yes
5	The thermometer is moved away from its intended position, reconfigured, or disconnected	Low	High	Low	No - Medium
6	Authentication and command actions are not recorded or are stolen	Critical	Medium	Medium	Yes
7	Requests flood the	Low	Critical	Low	No - High

	server, causing it to crash or process legitimate requests				
8	The control process crashes or enters an infinite loop causing it to stop functioning	Medium	High	High	Yes
9	Authentication and command requests are intercepted on the network	High	Critical	Critical	Yes

Justifications

Threat #1 - User performs unauthorized actions

Likelihood is medium because each authenticated user *should* be authorized to control the incubator, however, there are no authorization layers to control this.

Impact is high because users with access to the incubator have full control.

Risk is rated as medium; we agree with the severity rating because the intended use of the device is geared towards hospital users with physical access.

Post-Patch analysis: The risk here is still medium. Nothing has been updated to affect the authorization of the system.

Threat #2 - Untrusted code replaces program binaries

Likelihood is minimal because the attacker would need to be highly sophisticated and are more likely to take other avenues for attack.

Impact is critical because the incubator would be in an unmanageable environment.

Risk is rated as low; we agree with the severity rating because the likelihood of an attacker replacing the running executables is substantially lower than the other attack vectors presented.

Post-Patch analysis: No code signing was put in place, the severity rating remains low.

Threat #3 - Heater is misplaced or mismanaged

Likelihood is low because this would usually be caused by mismanagement, rather than a malicious actor.

Impact is medium because the heater misplacement is likely to be not optimal rather than a safety concern.

Risk is rated as low; we agree with the severity rating because the physical presence of the heater will not critically affect the other components of the system.

Post-Patch analysis: No change was made to the thermometer readings, so the severity rating is unchanged.

Threat #4 - Temperature data is modified

Likelihood is low because the attacker will need access to the client/server machines or access to the hospital network, as well as conduct an attack that allows for modification of that data over the network.

Impact is high because incorrect temperature readings could cause the incubator to behave in unexpected and dangerous ways.

Risk is rated as low; we agree with the severity rating because of the low likelihood of the attack, which would also imply other security concerns within the hospital's system and would likely be detected prior to temperature data modification.

Post-Patch analysis: No change was made to the thermometer readings, so the severity rating is unchanged.

Threat #5 - Thermometer is misplaced or mismanaged

Likelihood is low because like the heater misplacement, this would usually be caused by physical mismanagement of the incubator.

Impact is high because incorrect temperature data would cause the system to cool or heat incorrectly, best case receiving no data or worst case tracking room temperature ensuring the heater does not turn off.

Risk is rated as low; we disagree with the severity rating because while the likelihood of the thermometer being mismanaged is low, and the impact of the thermometer not tracking the correct temperature of the incubator can become dangerous if the heater stays on without proper cutoff.

Post-Patch analysis: No change was made to the thermometer readings, so the severity rating is unchanged.

Threat #6 - Audit data is not recorded or stolen

Likelihood is critical because no audit records are being kept for login or temperature changes.

Impact is medium because the audit logs are retroactive in nature, there must be a valid reason for checking who was authenticated and changed temperatures.

Risk is rated as medium; we agree with the severity rating because audit data is not a necessity for the product. It should be an available feature, for security reasons as well as operational ones.

Post-Patch analysis: There is no change to the audit data severity, as it's still not included.

Threat #7 - Denial of service attack on the server

Likelihood is low because the attacker would need access to the hospital's network or the client the incubator connects to.

Impact is critical because crashing the process could leave the heater on, causing danger to the infant in the incubator.

Risk is rated as medium; we disagree with the severity rating because the server should be easy to set up with rate limiting, and the severity of this kind of attack warrants immediate remediation.

Post-Patch analysis: This has been mitigated by the server timeout check, and the severity was brought down from medium to low.

Threat #8 - Server/Client bugs cause unavailability

Likelihood is medium because the software seems to be in infancy, without tests, proper QA, or wide industry acceptance.

Impact is high because bugs in the client/server code could render the incubator inoperable, or worse, dangerous to the infants housed in the incubator.

Risk is rated as medium; we agree with the severity rating because the incubator code has a high probability of change before release, and consistent bugs in the software should be found in static or dynamic analysis conducted by QA before release.

Post-Patch analysis: This has been updated to be high, the patches have not been properly QA'd together, and there are high-risk changes being included for server timeout, SQL, run commands, and password encryption.

Threat #9 - Network traffic is intercepted

Likelihood is high because none of the network traffic between the client and server is encrypted.

Impact is critical because capturing or modifying the network traffic results in the incubator being completely overtaken by an attacker.

Risk is rated as critical; we agree with the severity rating because the encryption of network traffic should be implemented as soon as possible. Sending authorization requests or commands in clear text is a completely avoidable risk that should be mitigated before release.

Post-Patch analysis: This is still rated as critical, no encryption was added as a result of the patches.